Aide-mémoire TP 1 — reconnaissance passive

Les commandes (dans `osint-tools` : `docker compose --profile tools run --rm osint-tools bash`, dépôt monté dans `/work`)

```
# A1 périmètre
curl -s "https://crt.sh/?q=%25.<domaine>&output=json" | jq -r '.[].name_value' | sort -u
subfinder -d <domaine> -silent | dnsx -silent -a -resp
dig <domaine> MX +short ; dig <domaine> TXT +short ; dig _dmarc.<domaine> TXT +short
# A2 exposition (navigateur) : https://www.shodan.io/host/<ip>   ·
https://search.censys.io/hosts/<ip>
# A3 personnes
theHarvester -d <domaine> -b crtsh,certspotter,duckduckgo,hackertarget
grep -i '@<domaine>' /work/data/fuite-simulee.txt
# A4 code et documents (navigateur) : github.com/search?q=<pme>  ·  site:<domaine>
filetype:pdf  ·  "<domaine>" password  ·  site:<domaine> intitle:"index of"
exiftool plaquette.pdf
# A7 bonus, bac à sable seulement
nuclei -update-templates && nuclei -u http://dev-old.<domaine> -tags tech,misconfig,exposure -
o /out/nuclei-dev-old.txt
# hors ligne : jq -r '.[].name_value' /work/data/osint/crtsh.json | sort -u  ·  jq '.data[] |
{port, product, version}' /work/data/osint/shodan-<ip>.json
```

Passif ou actif ?

Passif (autorisé sur toute cible, RGPD respecté) : crt.sh, Shodan, Censys, moteurs de recherche, Wayback Machine, Have I Been Pwned, LinkedIn sans connexion, WHOIS/RDAP, DNS passif. Actif (bac à sable seulement) : `dig`/`dnsx` sur les serveurs de la cible, visite répétée du site, `nuclei`, `httpx`, scan de ports, tentative de connexion, et dans Maltego *To Website* / *Enumerate hostnames*. Interdit partout : tester un identifiant, télécharger une fuite entière, créer un faux profil, contacter quelqu'un.

Le journal (une ligne par action)

`horodatage | action | outil | source (URL ou fichier) | résultat | cotation`

`2026-10-27 14:02 | périmètre | crt.sh | https://crt.sh/?q=%25.pme-fictive.example | 6 noms, dev-old cert. 2025-04 | A2`

Échelle Admiralty (OTAN) : deux cotes indépendantes

Source		Information	
A	totalement fiable (crt.sh, journal officiel, bannière lue soi-même)	1	confirmée par d'autres sources indépendantes
B	généralement fiable (Shodan, CERT-FR, éditeur reconnu)	2	probablement vraie (cohérente, une seule source)
C	assez fiable (blog technique, forum spécialisé)	3	possiblement vraie
D	généralement peu fiable (réseau social anonyme)	4	douteuse
E	peu fiable (revendication d'attaquant)	5	improbable
F	fiabilité inconnue (fuite d'origine inconnue)	6	véracité inconnue

Exemples : sous-domaines lus dans crt.sh et confirmés par dnsx → A1 ; version Apache lue dans la bannière Shodan, non confirmée → B2 ; CVE « suggérée » par Shodan d'après la version → B3 ; adresses présentes dans

une fuite d'origine inconnue → F3 pour la fuite, A1 pour la présence des adresses ; technologie citée dans une offre d'emploi → A2. Une source F peut livrer une information 1 : on ne somme jamais les deux cotes.

Les constats attendus d'une fiche (trois à cinq, par priorité)

Pour chacun : ce qu'on a vu (fait, source, date), pourquoi c'est un risque (ce que l'attaquant en fait), la recommandation (actionnable : « fermer 3389, accès par VPN avec MFA », pas « sécuriser le serveur »). Anonymiser les adresses (`m.d***@`). Marquage TLP:AMBER : la fiche contient des détails exploitables sur une organisation.

Maltego en quatre gestes

Entité *Domain* → clic droit → *To DNS Name* ; sur chaque DNS Name → *To IP Address* ; sur chaque IP → *To Netblock* ; ajouter *Email Address* et relier au domaine. Export : menu *Import* | *Export* → *Export Graph to Image*. Plan Basic : 24 résultats par transformation. Compte non activé : dessiner le graphe (draw.io) ; la carte compte, pas l'outil.